Week 14 VPN

06016421 IT Infrastructure Security
by P. Sumet, IT/KMITL

References

- VPN Meaning: What Does VPN Stand For?
- IPsec VPN - NIST's Guide to IPsec VPNs (PDF) , IPsec VPN concepts
- SSL VPN - NIST's Guide to IPsec VPNs (PDF), SSL VPN Explained

IPsec VPN

06016421 IT Infrastructure Security
by P. Sumet, IT/KMITL

IPsec VPN - A Summary

IPsec (Detailed in P.53/166)

- A network layer security control which can provide several types of protection for data, depending on its configuration.
- A framework of open standards for ensuring private communications over IP networks and is the standard used for network layer security control. It can provide several types of protection, including maintaining confidentiality and integrity, preventing packet replay attacks and traffic analysis, and enforcing access restrictions.

Internet Key Exchange (IKE) (Detailed in P.37/166)

- The protocol that is used to negotiate, update, and maintain IPsec connections.

VPN

- A virtual network built on top of existing networks that can provide a secure communications mechanism for data and IP information transmitted between networks.
- It can be used to secure communication between individual hosts (host-to-host) or multiple networks (gateway-to-gateway) or to provide secure remote access for mobile devices to a home or enterprise network. Hosts within a network can build a mesh of IPsec connections between all nodes or use a security controller to assist them with building VPN connections to other nodes.
- Although VPNs can reduce the risks of operating over an insecure network, they cannot eliminate them. For example, a VPN implementation may have flaws in algorithms or software that attackers can exploit. Also, VPN implementations often have at least a slightly negative impact on availability because they add components and services to existing network infrastructures.

What is IPsec or the IPsec Protocol? (P.23/166)

- The most commonly used network layer security control for protecting communications.
- A framework of open standards for ensuring private communications over IP networks.
- The Internet Key Exchange (IKE) protocol is used to securely negotiate IPsec parameters and encryption keys.
- The IPsec Working Group at the Internet Engineering Task Force (IETF) is responsible for maintaining and publishing the standards for IKE and IPsec.
- It can provide any combination of the following types of protection:
  - Confidentiality, Integrity,
  - Confidentiality and Integrity (Both types of checks can be combined into one Authenticated Encryption with Associated Data (AEAD) algorithm),
  - Peer Authentication, Replay Protection, Traffic Analysis Protection, Access Control, Perfect Forward Secrecy (PFS),
  - Mobility
    - The outer IP address of an endpoint can change without causing an interruption to the encrypted data flow. Since the application is communicating using the inner (encrypted) IP address, it does not matter that the outer IP address changes. This allows a device to switch from WiFi to Ethernet to mobile data without application interruption.

Cryptographic Security Services provided by IPsec for VPNs (P.25/166)

Confidentiality :

- VPNs use symmetric cryptography to encrypt and decrypt their command and data channels.
  - NIST approved algorithms that implement symmetric encryption include the Advanced Encryption Standard (AES) and the Triple Data Encryption Standard (3DES). 7 One of the NIST-approved modes for symmetric encryption algorithms is AES-Galois Counter Mode (AES-GCM)

Integrity :

- Common algorithms that implement integrity protection are:
  - The keyed-hash message authentication code (HMAC) algorithm specified in FIPS-198 which uses a hash function from FIPS-180 (i.e., SHA-1 or the SHA-2 family of hash functions, also known as HMAC-SHA-2). The SHA-3 family might be added in the future.

Establishment of Shared Secret Keys :

- VPNs typically use the DH key exchange algorithm to create a confidential communication channel to calculate a shared key between the two endpoints that an eavesdropper cannot obtain or compute.
- DH key exchanges can be based on finite field cryptography (“classic” or “modular” DH) or on elliptic curve cryptography (ECDH).
- After performing the DH key exchange and calculating the shared key, the endpoints still need to authenticate each other to ensure that the confidential communication channel is set up with the expected party and not somebody else.

Peer Authentication :

- VPNs usually use asymmetric cryptography for identity authentication. Such a public/private key pair can be used by itself or contained within an X.509 certificate.
- A VPN entity is authenticated by proving it has possession of the private key that corresponds to a known public key as well as the secret key computed by the parties during the DH key exchange. This binds the private communication channel (i.e., the VPN) to the expected identities. The public key can verify this proof without having a copy of the private key. Thus, as long as both parties each have the other’s public key and their own private key, they can establish an authenticated private channel through which they can communicate.
- A less secure method of identity authentication is using a pre-shared key (PSK). Parties authenticate each other’s identity based on the fact that no one else has possession of this shared key, which must be established out-of-band. 11 A VPN entity’s identity is authenticated by proving that it has possession of the PSK as well as the secret key computed by the parties during the DH key exchange. This binds the private communication channel to the expected identities.

Primary IPsec-Based VPN Architectures (P.28/166)

Gateway-to-gateway

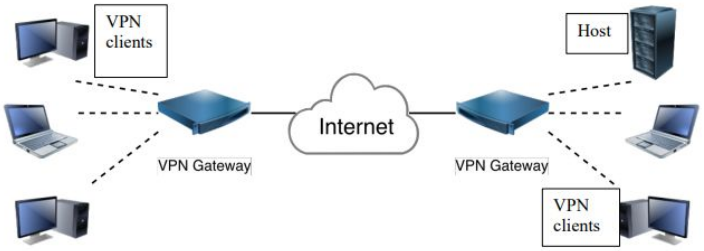


Figure 2: Gateway-to-Gateway VPN Architecture Example

Host-to-host

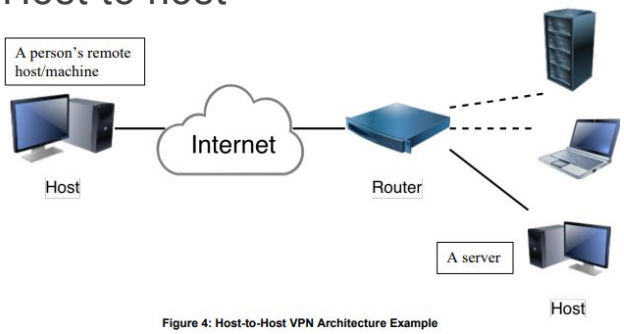


Figure 4: Host-to-Host VPN Architecture Example

Remote access

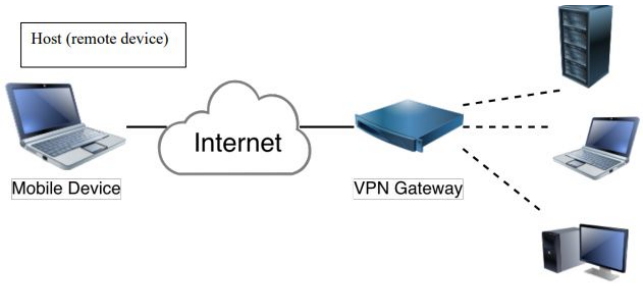


Figure 3: Remote Access VPN Architecture Example

Mesh

A special case of host-to-host VPNs is a large-scale host-to-host IPsec deployment. This is typically used when one wants to encrypt all connections within a network, cloud, or datacenter.

Whenever one host in such a network wishes to communicate with another host in the network, it first establishes an IPsec connection.

Planning and Implementation Case Studies (P.110/166)

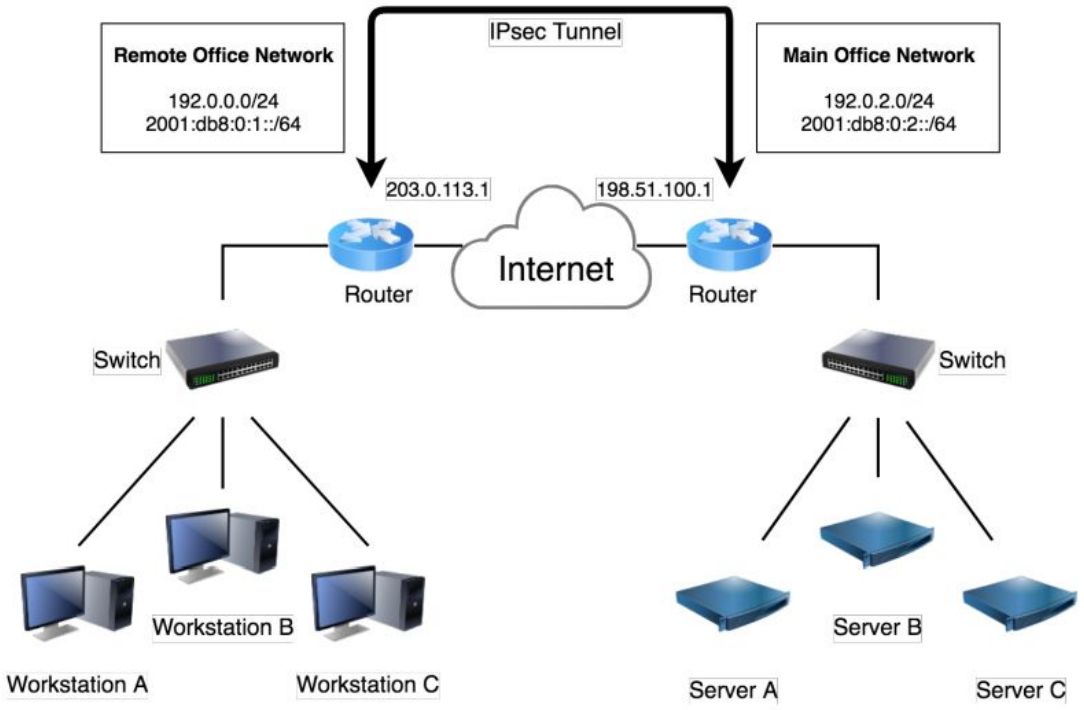
- Protecting communications between two LANs (i.e., remote office, main office)
- Protecting wireless communications in a small office/home office environment
- Protecting communications between remote users (e.g., telecommuters, road warriors) and the main office's network
- Protecting a datacenter or cloud network using mesh encryption

แนวทางการดำเนินงานสำหรับแต่ละกรณีศึกษา (P.110/166)

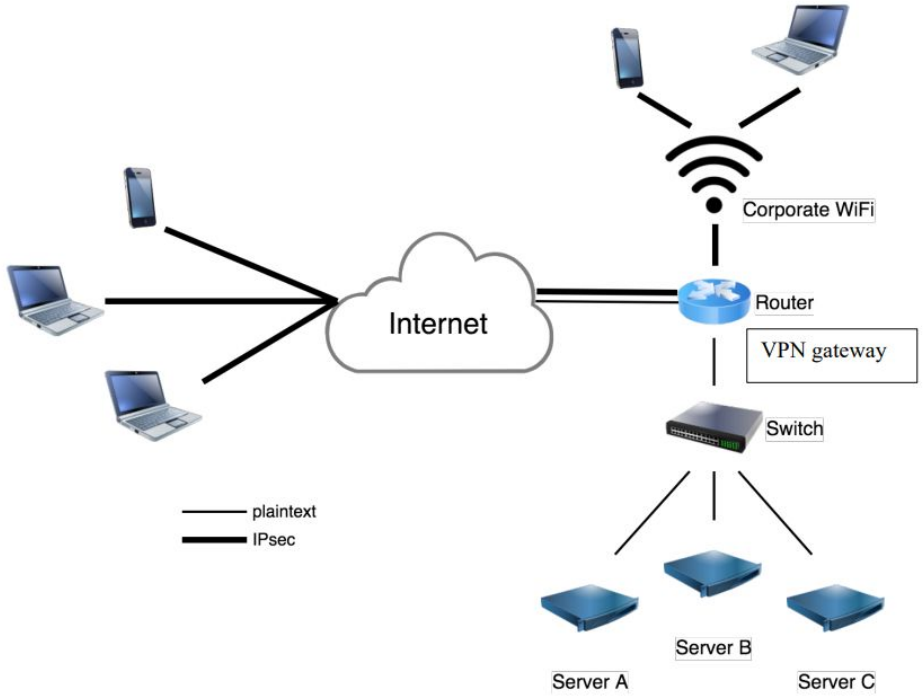
Based on แต่ละ Case Study (ตั้งแต่ P.110/166 หัวข้อ 9.1 - 9.4) จะมีรายละเอียดดังนี้

- Identifying Needs and Evaluating Options ~ Conceptual Design
  - Data Link Layer Solution: Leased Line
  - Network Layer Solution: Network Layer VPN
  - Transport Layer Solution: Web-Based Applications
  - Application Layer Solution: Application Modification
- Designing the Solution ~ Logical Design
  - เกี่ยวกับ Architecture and Engineering
  - สิ่งที่ได้คือ Network Diagram and Related Technologies as well as Tools.
- Implementing a Prototype
  - สิ่งที่จะต้องทำหรือปฏิบัติ และคำสั่งหรือคอนฟิกที่จะทำที่ Host และ อุปกรณ์ต่างๆ
- Analysis
  - วิเคราะห์และประเมินผลที่ได้

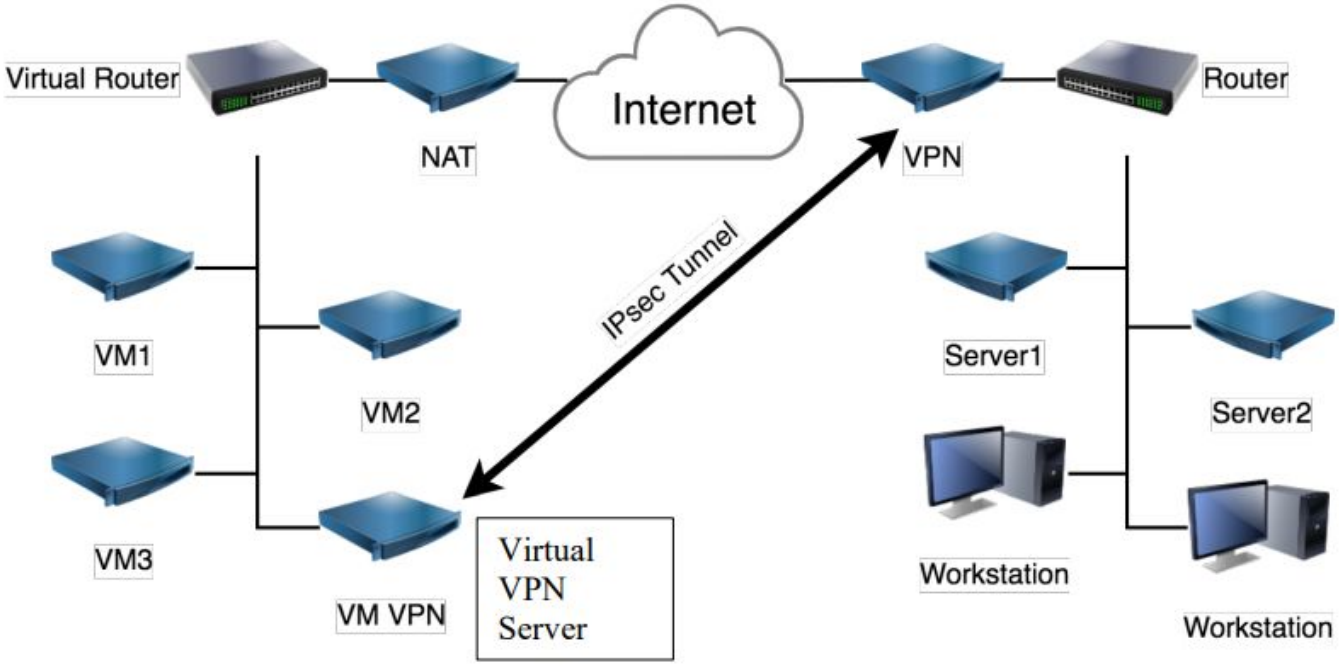
A. Gateway-to-Gateway VPN for Remote Office Connectivity (P.110/166)



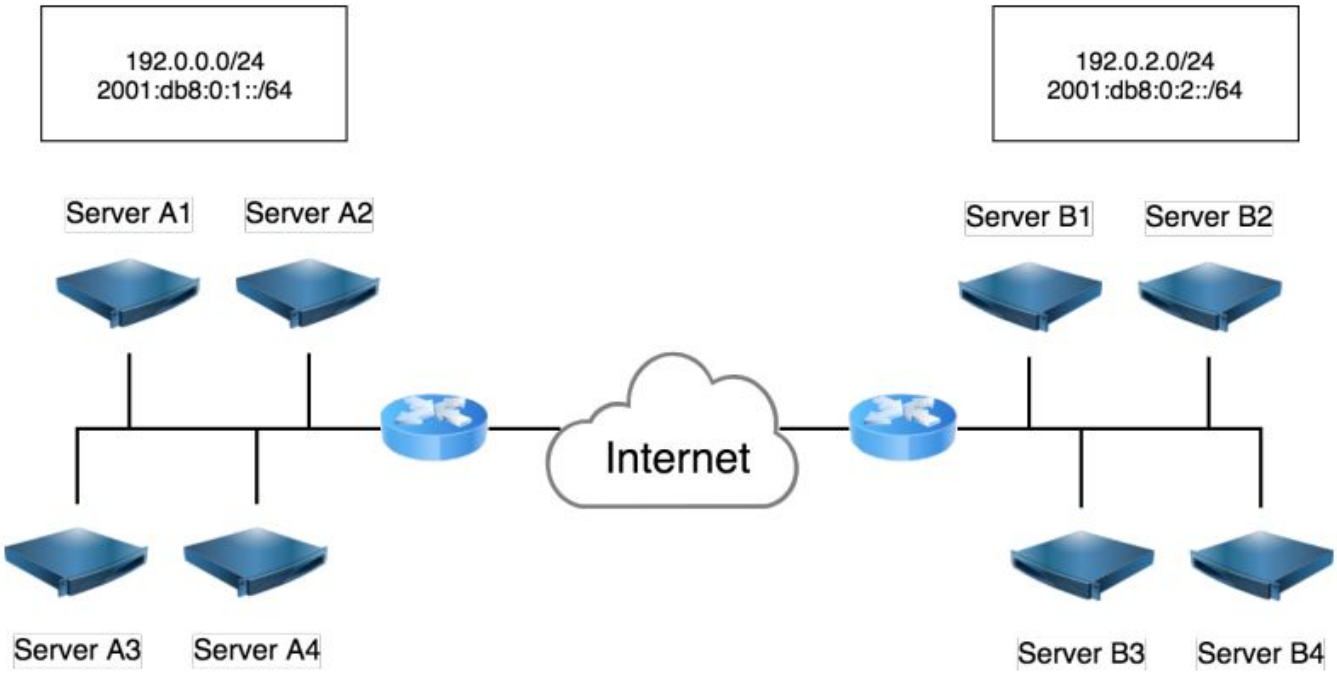
B. Remote Access VPN for Protecting Communications (P.123/166)



C. Remote Access to a Cloud-Based Virtual Network (P.129/166)



D. Mesh Encryption Using IPsec (P.133/166)



SSL VPN

06016421 IT Infrastructure Security
by P. Sumet, IT/KMITL

SSL VPN Architecture (P.20/87)

Primary models for SSL VPN architectures

- SSL portal VPN
  - These VPNs allow remote users with almost any Web browser to connect to a VPN gateway and access services from a Web site provided on the gateway.
  - SSL portal VPNs are more accessible to a wider range of users than SSL tunnel VPNs because they can be run on more Web browsers, particularly those whose security policies prevent running of active content that is downloaded from the Internet.
- SSL tunnel VPN
  - These VPNs allow remote users with Web browsers that allow active content to access the network protected by a VPN gateway. SSL tunnel VPNs have many more capabilities than SSL portal VPNs because more services can be provided more easily.

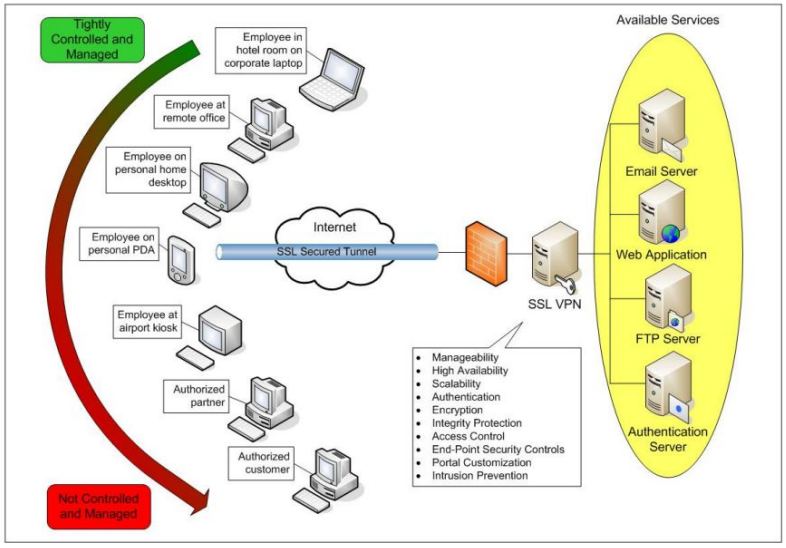


Figure 3-1. SSL VPN Architecture

SSL VPN Functions (P.21/87)

- Proxying
  - An intermediary device or program that provides communication and other services between a client and server.
- Application Translation
  - It converts information from one protocol to another.
- Network Extension
  - A method of providing partial or complete network access to remote users. Users can connect to the network and access internal resources as if they were physically located on the internal local area network (LAN).

SSL VPN Features and Security Services (P.22/87)

- Manageability
- High availability and Scalability
  - High availability solutions use two or more SSL VPN devices configured in either active/passive or active/active mode.
  - SSL VPNs support scalability with load-balancing features. Both high availability and load balancing often use a virtual IP address that is shared across multiple SSL VPN devices.
- Portal Customization
  - A feature that allows an administrator to control the appearance of the SSL VPN Web interface that the end users see and with which they interact.
- Authentication
- Encryption and integrity protection
- Access control
- Endpoint security controls
- Intrusion prevention

Table 3-1. Access Control Examples

Method	Example
Per-user	The CEO may access all intranet servers, email, and the executive folder of the administrative server.
Per-group	Sales staff may access email, the organization's intranet, and the sales server.
Per-resource	All users and groups may access the Community Relations server.

Table 3-2. Access Control Examples with Endpoint Security Controls

User	Group	Location	Security Checks	Access
CEO	• Executive • Employees	Home	Firewall: passed Antivirus: passed	The CEO may access all intranet servers, email, and the executive folder of the administrative server. He may also access the Community Relations server.
John Smith	• Sales • Employees	Internet café	Firewall: passed Antivirus: *failed*	John Smith may only access email and perform downloads from the sales server. He may also access the Community Relations server.
Sally Jones	• XYZ Corp. (Business Partner)	Partner network	Firewall: passed Antivirus: passed	Sally Jones may access the extranet partner server and the Community Relations server.

SSL Protocol Basics (P.28/87)

- The security of the data sent over an SSL VPN relies on the security of the SSL protocol.
- The SSL protocol allows a client (such as a Web browser) and a server (such as an SSL VPN) to negotiate the type of security to be used during an SSL session.
- Thus, it is critical to make sure that the security agreed to by the remote user and the SSL gateway meets the security requirements of the organization using the SSL VPN.
- There are three types of security that the client and server can negotiate:
  - The version of SSL, the type of cryptography, and the authentication method.
- Versions of SSL and TLS
- Cryptography Used in SSL Sessions
- Authentication Used for Identifying SSL Servers

SSL VPN Challenges (P.30/87)

- Application and client interoperability
  - SSL VPNs must be able to export a large variety of applications to remote connections of various types.
  - There are many factors that can affect interoperability, including operating system type and version, browser type and version, device type (e.g., laptop, PDA, smart phone), location (e.g., home or public kiosk), and the specifics of the applications and protocols to be accessed.
- Client/server application support
- Network extension
- Endpoint security
- Clientless operation

SSL VPN Planning and Implementation (P.33/87)

1. Identify Requirements

The first phase of the process involves identifying the current and future requirements for remote access and determining how they can best be met by an SSL VPN implementation. Determining requirements for U.S. federal agencies also means assessing how to comply with FIPS 140-2.

2. Design the Solution

The second phase involves all aspects of designing an SSL VPN solution. The design elements are grouped into five categories: access control, endpoint security, authentication methods, architecture, and cryptography policy.

3. Implement and Test a Prototype

The next phase involves implementing and testing a prototype in a laboratory or test environment. The primary goals are to evaluate all aspects of the solution including authentication, application compatibility, management, logging, performance, security of the implementation, design and layout of the VPN portal, and default settings.

4. Deploy the Solution

Once testing is completed and all issues are resolved, the next phase includes the deployment of the SSL VPN throughout the enterprise. This phase addresses issues specific to SSL VPNs that may occur during deployment. Support must be addressed, and this includes the process of working with a help desk to provide assistance for end users.

5. Manage the Solution

After the SSL VPN solution has been deployed, it must be managed throughout its lifecycle. Management includes maintenance (e.g., patching, solution expansion, key management, policy changes), performance monitoring, and periodic testing/validation of the solution. The handling of operational issues must also be considered.

Design the Architecture (P.44/87)

1. Selection of Hardware Configuration
2. Device Placement and Firewall Configuration
3. Routing Policy and Other Network Considerations
   Routing policy is as important as firewall configuration.
   Packets must be routed correctly within the internal network
   for the VPN to function properly.
4. High Availability or Load Balancing Support
5. Management
6. Client Software Selection
   The organization will have to ensure that these agents can run
   on client machines if the agents are required by access control
   and endpoint security policies.
7. Portal Design
   The organization should provide a portal for users
   so they can login to the SSL VPN and gain access to
   internal resources.

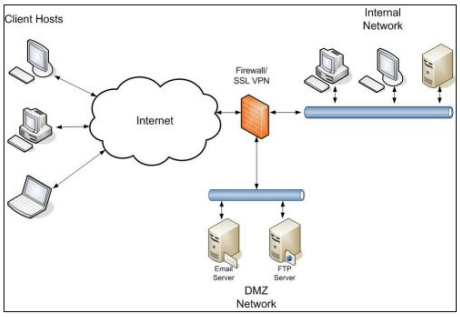


Figure 4-1. Firewall with SSL VPN Functionality

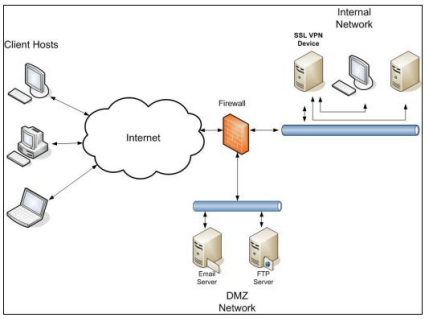


Figure 4-2. SSL VPN Device in Internal Network

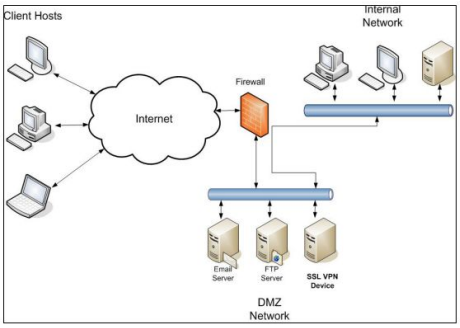


Figure 4-3. SSL VPN Device in DMZ Network

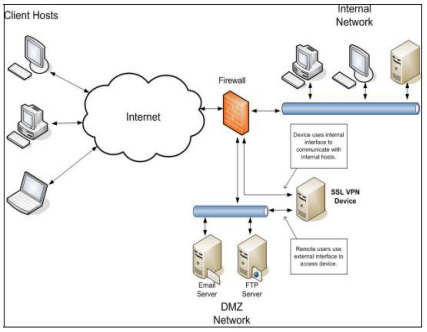


Figure 4-4. SSL VPN Device with Two Interfaces

Implement and Test Prototype (P.57/87)

Connectivity

Authentication

Access Control

Application and Client Interoperability (P.59/87)

Management (of Devices, Server, and Client) and Network Management

Logging

Performance

Portal Design and Layout

Security of the Implementation

Endpoint Security

Default Settings (ทบทวน Default Settings ที่มีอยู่เยอะแยะในทุกส่วนของ SSL VPN Setup)

SSL VPN Planning and Implementation - A Summary

1. Identify Requirements.

   Identify the requirements for remote access and determine how they can best be met.

2. Design the Solution.

   Make design decisions in five areas: access control, endpoint security, authentication methods, architecture, and cryptography policy.

3. Implement and Test a Prototype.

   Test a prototype of the designed solution in a lab, test, or production environment to identify any potential issues.

4. Deploy the Solution.

   Gradually deploy the SSL VPN solution throughout the enterprise, beginning with a pilot program.

5. Manage the Solution.

   Maintain the SSL VPN components and resolve operational issues. Repeat the planning and implementation process when significant changes need to be incorporated into the solution.

Alternatives to SSL VPNs (P.70/87)

Point-to-Point Tunneling Protocol (PPTP) Version 2

Layer 2 Tunneling Protocol (L2TP)

Layer 2 Forwarding (L2F)

VPN Protocol	IP Protocols
PPTP	47 (Generic Routing Encapsulation) 6 (TCP), port 1723
L2TP	17 (UDP), port 1701
L2F	17 (UDP), port 1701
IPsec	50 (Authentication Header, for AH connections) 51 (Encapsulating Security Payload, for ESP connections) 17 (UDP), port 500 (for Internet Key Exchange, whether or not NAT-Traversal is used) 17 (UDP), port 4500 (for Internet Key Exchange using NAT-Traversal)
SSL	6 (TCP), port 443

Comparison of SSL and Alternatives (P.73/87)

Table 6-1. Comparison of SSL and Alternatives

Name	Primary Strengths	Primary Weaknesses	Potential Cases for Use Instead of SSL
PPTP	+ Can protect non-IP protocols	- Requires client software to be configured (and installed on hosts without a built-in client) - Has known security weaknesses - Does not offer strong authentication - Only supports one session per tunnel	None
L2TP	+ Can protect non-IP protocols + Can support multiple sessions per tunnel + Can use authentication protocols such as RADIUS + Can use IPsec to provide encryption and key management services	- Requires client software to be configured (and installed on hosts without a built-in client)	Protecting dial-up communications
L2F	+ Can protect non-IP protocols + Transparent to clients + Can use authentication protocols such as RADIUS	- Requires each ISP's participation - Does not protect communications between the clients and the ISP - Does not offer encryption; must rely on PPP encryption services, which have known weaknesses	None
IPsec	+ Already supported by most operating systems + Can provide strong encryption and integrity protection + Transparent to clients in gateway-to-gateway architecture + Can use a variety of authentication protocols	- Can only protect IP-based communications - Requires client software to be configured (and installed on hosts without a built-in client) for host-to-gateway and host-to-host architectures - Does not protect communications between the clients and the IPsec gateway in gateway-to-gateway architectures	Protecting all communications between networks, such as supporting connectivity for a remote site
SSL	+ Already supported by all major Web browsers + Can provide strong encryption and integrity protection + Can provide multiple layers of authentication + Transparent to users + Granular access control	- Can only protect TCP-based communications - Requires application servers and clients to support SSL - Configured on an application-by-application basis	N/A

See also…

SSL VPN Recommended Practices P.64/87

Case Study P.75/87

Lab 7 - VPN

06016421 IT Infrastructure Security
by P. Sumet, IT/KMITL

VPN Server using Fortigate (FGT)

- IP Sec
  - Site to Site
  - Remote Access
    - Client-based (ใช้ Forticlient คล้ายๆ kerio ที่คณะใช้)
    - Native (ใช้ VPN Client ของ OS ของ Host)
- SSL
  - Tunnel Mode
  - Web Mode

Lab 7 : การเปรียบเทียบ Insecure Connection vs Secured Connection using VPN

Lab 7-A Insecure Connection

Lab 7-B Secured Connection using VPN (IPsec VPN แบบ Site to Site)

Lab 7-C Secured Connection using VPN (SSL VPN แบบ Remote Access ผ่าน Web Browser) (Option)

Lab Manual : https://docs.fortinet.com/document/fortigate/6.4.15/administration-guide/954635/getting-started

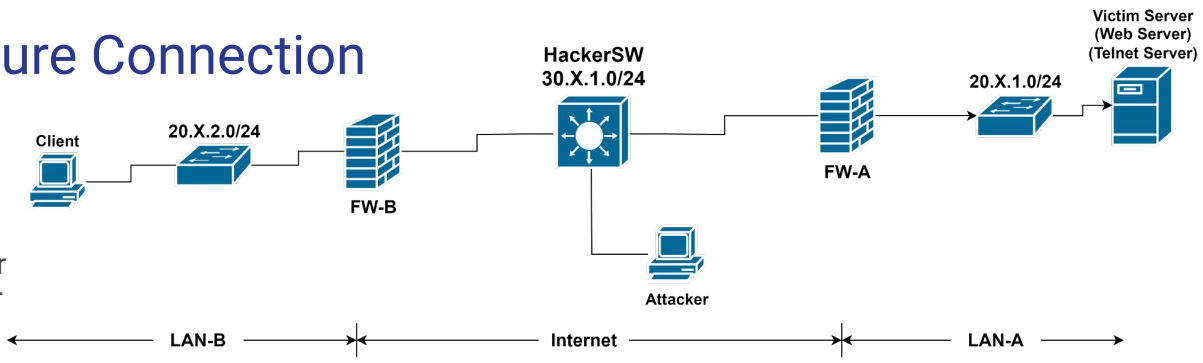
https://docs.fortinet.com/document/fortigate/6.4.15/administration-guide/520377/ipsec-vpns

https://docs.fortinet.com/document/fortigate/6.4.15/administration-guide/371626/ssl-vpn

https://docs.fortinet.com/document/fortigate/6.2.16/cookbook/579694/ssl-vpn-web-mode-for-remote-user

https://docs.fortinet.com/document/fortigate/6.4.15/administration-guide/100733/ssl-vpn-web-mode

Lab 7-A : Insecure Connection



1. สร้างเครือข่ายดังรูป

2. ที่ Hacker Sw ให้ทำ Mirror Packet ไปเครื่อง Attacker

3. ติดตั้ง Web Server ทำงานบน HTTP
   และ Telnet Server สร้าง User ชื่อ itxxx รหัสผ่าน kmitlxxx โดยให้ xxx คือ เลข 3 ตัวท้ายของรหัส นศ ที่ทำรายงาน

4. ที่ Attacker PC ให้รัน tcpdump เพื่อ capture traffic ดังนี้
   4.1. tcpdump -n -A -i <interface> (อาจจะต่อท้ายด้วย 1>Lab07A.txt 2>Lab07A-err.txt เพื่อบันทึกลงไฟล์)
   4.2. tcpdump -n -A -i <interface> -w Lab07A.pcap (บันทึกเป็นไฟล์ไปเปิดดูด้วย wireshark)

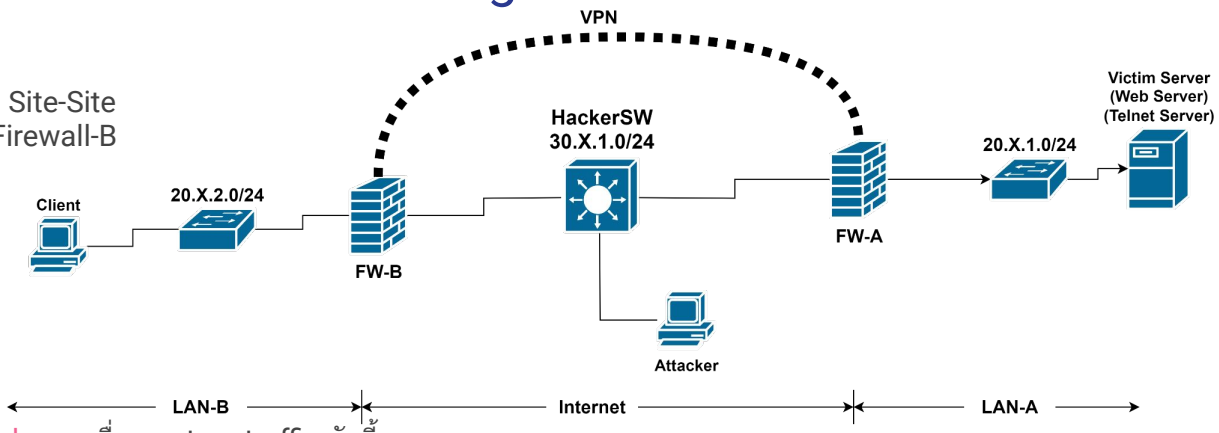
5. ที่ Client ทดลอง
   5.1. curl http://<server IP>
   5.2. telnet <server IP> แล้วลองป้อน loginname และ password อะไรก็ได้ (จะ login สำเร็จหรือไม่ก็ได้)
   5.3. curl http://<server IP>/xxxxxx.html

6. ยุติการบันทึกในข้อ 4 แล้วนำผลการทดลองมาอธิบาย ดูว่าเราสามารถอ่านข้อมูลที่ Client และ Server คุยกันได้หรือไม่ ให้แนบผลการ Capture ด้วย pcap ไฟล์จากข้อ 4.2 ด้วย

Lab 7-B : Secured Connection using VPN

(ต่อจาก Lab 7-A)

1. เชื่อมต่อ IPSec VPN แบบ Site-Site
   ระหว่าง Firewall-A และ Firewall-B



2. ที่ Attacker PC ให้รัน tcpdump เพื่อ capture traffic ดังนี้
   2.1. tcpdump -n -A -i <interface> (อาจจะต่อท้ายด้วย 1>Lab07B.txt 2>Lab07B-err.txt เพื่อบันทึกลงไฟล์)
   2.2. tcpdump -n -A -i <interface> -w Lab07B.pcap (บันทึกเป็นไฟล์ไปเปิดดูด้วย wireshark)

3. ที่ Client ทดลอง
   3.1. curl http://<server IP>
   3.2. telnet <server IP> แล้วลองป้อน loginname และ password อะไรก็ได้ (จะ login สำเร็จหรือไม่ก็ได้)
   3.3. curl http://<server IP>/xxxxxx.html

4. ยุติการบันทึกในข้อ 2 แล้วนำผลการทดลองมาอธิบาย ดูว่าเราสามารถอ่านข้อมูลที่ Client และ Server คุยกันได้หรือไม่
   ให้แนบผลการ Capture ด้วย pcap ไฟล์จากข้อ 2.2 ด้วย